



Instituto Federal da Bahia
Engenharia de Sistemas e Produtos

Programa de Pós-Graduação em Engenharia de Sistemas e Produtos

**SISTEMA AUTÔNOMO DE AUTENTICAÇÃO
CONTEXTUAL COM BLOCKCHAIN E IA**

João Guedes de Brito

QUALIFICAÇÃO DE MESTRADO

Salvador - 05/03/2026

JOÃO GUEDES DE BRITO

**SISTEMA AUTÔNOMO DE AUTENTICAÇÃO CONTEXTUAL COM
BLOCKCHAIN E IA**

Esta Qualificação de Mestrado foi apresentada ao Programa de Pós-Graduação em Engenharia de Sistemas e Produtos, do Instituto Federal da Bahia, como requisito parcial para obtenção do grau de Mestre em Engenharia de Sistemas e Produtos.

Orientador: Cleber Jorge Lira de Santana

RESUMO

O presente projeto propõe o desenvolvimento de um sistema autônomo de autenticação contextual baseado em Inteligência Artificial (IA) e tecnologia Blockchain, com o objetivo de aumentar a segurança, a confiabilidade e a adaptabilidade dos processos de login em aplicações web. A proposta parte da constatação de que métodos tradicionais de autenticação — como senhas fixas ou autenticação em dois fatores — embora amplamente utilizados, estão cada vez mais vulneráveis a ataques cibernéticos sofisticados e não consideram o contexto comportamental do usuário. Nesse cenário, a pesquisa busca implementar uma abordagem inovadora que analisa dados contextuais (como localização, horário de acesso, dispositivo e padrão de uso) para reforçar a tomada de decisão sobre a concessão de acesso.

A arquitetura do sistema é baseada em microserviços, utilizando Spring Boot no backend e Angular no frontend, com a integração de Keycloak como gerenciador de identidade. O sistema incluirá um serviço de Machine Learning, responsável por processar e classificar os acessos com base em modelos supervisionados desenvolvidos com Scikit-learn. A tecnologia Blockchain será explorada para registrar de forma imutável os logs de autenticação, garantindo rastreabilidade e transparência dos acessos. O projeto prevê ainda a utilização do ELK Stack (Elasticsearch, Logstash e Kibana) e Grafana para o monitoramento e análise em tempo real dos dados do sistema.

Do ponto de vista metodológico, o projeto adotará um ciclo iterativo de desenvolvimento ágil, com testes e validações em ambientes controlados. Espera-se que a solução proposta possa ser aplicada em ambientes corporativos, acadêmicos e governamentais, contribuindo para o avanço das tecnologias de segurança digital, além de abrir caminho para estudos mais aprofundados sobre autenticação adaptativa e descentralizada. O impacto regional e nacional reside na crescente demanda por soluções seguras e inteligentes diante do aumento exponencial de ataques cibernéticos e da necessidade de conformidade com legislações como a LGPD.

Palavras-chave: Contextual Authentication; Artificial Intelligence; Blockchain; Information Security; Machine Learning; Keycloak; Microservices; Angular; Spring Boot; LGPD (General Data Protection Law – Brazil).

ABSTRACT

This project proposes the development of an autonomous contextual authentication system based on Artificial Intelligence (AI) and Blockchain technology, with the aim of enhancing the security, reliability, and adaptability of login processes in web applications.

The proposal stems from the observation that traditional authentication methods — such as static passwords or two-factor authentication — although widely used, are increasingly vulnerable to sophisticated cyberattacks and do not take into account the user's behavioral context. In this scenario, the research seeks to implement an innovative approach that analyzes contextual data (such as location, access time, device, and usage patterns) to support the decision-making process regarding access granting.

The system architecture is based on microservices, using Spring Boot on the backend and Angular on the frontend, with the integration of Keycloak as the identity management provider. The system will include a Machine Learning service responsible for processing and classifying access requests based on supervised models developed with Scikit-learn. Blockchain technology will be explored to immutably record authentication logs, ensuring traceability and transparency of accesses. The project also includes the use of the ELK Stack (Elasticsearch, Logstash, and Kibana) and Grafana for real-time monitoring and analysis of system data.

From a methodological standpoint, the project will adopt an iterative agile development cycle, with testing and validation in controlled environments. It is expected that the proposed solution can be applied in corporate, academic, and governmental settings, contributing to the advancement of digital security technologies, while also paving the way for more in-depth studies on adaptive and decentralized authentication. The regional and national impact lies in the growing demand for secure and intelligent solutions in the face of the exponential increase in cyberattacks and the need for compliance with legislation such as Brazil's General Data Protection Law (LGPD).

Keywords: temperature control, Peltier effect, thermoelectricity, thermoelectric module.

LISTA DE FIGURAS

Figura 1 — Arquitetura em Cinco Camadas do Sistema Proposto15

Figura 2 — Fluxo de Autenticação Contextual (Diagrama de Sequência)17

Figura 3 — Pipeline de ML: Treinamento e Inferência em Produção20

Figura 4 — Estrutura de Blocos — Registro Imutável de Eventos de Autenticação21

Figura 5 — Resultados Parciais: Métricas de ML e Comparativo de Latência24

LISTA DE SIGLAS

- **API** – Application Programming Interface
- **CI/CD** – Continuous Integration / Continuous Delivery
- **DAST** – Dynamic Application Security Testing
- **IA** – Inteligência Artificial
- **JWT** – JSON Web Token
- **ML** – Machine Learning
- **MFA** – Multi-Factor Authentication
- **OAuth2** – Open Authorization 2.0
- **OIDC** – OpenID Connect
- **OWASP** – Open Web Application Security Project
- **REST** – Representational State Transfer
- **SAST** – Static Application Security Testing

SUMÁRIO

INTRODUÇÃO	9
1.1.Contextualização do projeto	9
1.2.Objetivos Gerais.....	10
1.3.Objetivos específicos.....	10
1.4.Justificativa do projeto	10
FUNDAMENTAÇÃO TEÓRICA	12
2.1 Segurança de Aplicações Web.....	12
2.2 DevSecOps	13
2.3 Inteligência Artificial Aplicada à Cibersegurança.....	14
2.4 Blockchain como Mecanismo de Integridade e Auditoria	14
DESENVOLVIMENTO	16
3.1 Visão Geral da Arquitetura Proposta	16
3.2 Tecnologias Utilizadas	20
3.3 Pipeline DevSecOps	22
3.4 Integração da Inteligência Artificial	23
3.5 Implementação da Blockchain	23
3.6 Critérios de Liberação ou Negação.....	24
3.7 Ambiente Experimental.....	25
3.8 Métricas de Avaliação.....	25
3.9 Fluxo Operacional.....	26
RESULTADOS PARCIAIS	27
4.1 Configuração do Ambiente Experimental.....	27
4.2 Testes Realizados e Metodologia	28
4.3 Resultados Obtidos.....	28
4.4 Discussão e Análise dos Resultados	29
4.5 Dificuldades Encontradas	30
CRONOGRAMA DE ATIVIDADES	31
5.1 Cronograma	31
REFERÊNCIAS BIBLIOGRÁFICAS	32

Neste capítulo apresento a introdução do projeto, contextualização, objetivos gerais, objetivos específicos, justificativa e estrutura do trabalho.

INTRODUÇÃO

1.1. Contextualização do projeto

Em um mundo digital cada vez mais conectado, garantir a segurança dos processos de autenticação de usuários tornou-se um desafio crítico. Métodos tradicionais, como senhas fixas e autenticação em dois fatores (2FA), embora ainda amplamente utilizados, vêm demonstrando limitações diante do aumento da complexidade dos ataques cibernéticos e da evolução do comportamento dos usuários. Esses mecanismos, em sua maioria, não consideram a natureza dinâmica e contextual das interações digitais, influenciadas por variáveis como horário, localização, dispositivo e padrões de uso.

Esse cenário evidencia a necessidade de soluções de autenticação mais inteligentes, adaptáveis e seguras. Nesse contexto, o presente projeto propõe o desenvolvimento de um sistema autônomo de autenticação contextual, integrando Inteligência Artificial (IA), Blockchain e uma arquitetura baseada em microserviços, com o objetivo de aprimorar o controle de acesso em aplicações web. Por meio da análise de dados contextuais e do uso de modelos supervisionados de Machine Learning, o sistema buscará tomar decisões em tempo real sobre a concessão ou negação de acesso, com base em padrões de comportamento.

A arquitetura contempla o uso de tecnologias modernas como Spring Boot,

Angular, Keycloak para gestão de identidade e Scikit-learn para o desenvolvimento dos modelos de IA. Além disso, a tecnologia Blockchain será utilizada para garantir a imutabilidade e a transparência dos registros de autenticação, enquanto o ELK Stack e o Grafana serão empregados para o monitoramento e análise em tempo real dos dados do sistema.

A pesquisa está alinhada às tendências atuais de Segurança da Informação e responde à crescente demanda por soluções adaptativas e em conformidade com legislações, como a Lei Geral de Proteção de Dados (LGPD). Espera-se que o projeto contribua com os setores acadêmico, corporativo e público, promovendo avanços na área de autenticação digital.

1.2. Objetivos Gerais

Desenvolver um sistema autônomo de autenticação contextual que integre IA e Blockchain para reforçar a segurança de acesso a sistemas digitais.

1.3. Objetivos específicos

O projeto tem como objetivos específicos: (1) desenvolver uma arquitetura de segurança integrada baseada em DevSecOps para aplicações web críticas; (2) implementar mecanismos automatizados de detecção de vulnerabilidades utilizando análise estática, dinâmica e inteligência artificial; (3) integrar mecanismos de monitoramento contínuo via SIEM/SOAR para resposta automatizada a incidentes; e (4) validar experimentalmente a eficácia da solução por meio de testes controlados em ambiente simulado, medindo redução de vulnerabilidades, tempo de resposta a incidentes e conformidade com padrões federais de segurança.

1.4. Justificativa do projeto

A escolha deste tema justifica-se pela urgência em aprimorar os mecanismos de autenticação frente às vulnerabilidades dos sistemas tradicionais e ao crescimento exponencial dos ciberataques. A relevância da pesquisa está na proposição de um

sistema que não apenas reaja a ameaças, mas que atue de forma autônoma e preditiva, analisando contextos e tomando decisões inteligentes.

A viabilidade do projeto está garantida pela utilização de tecnologias maduras como o Keycloak (para gerenciamento de identidade), Angular (para interface), Spring Boot (para o backend), bibliotecas de machine learning (como Scikit-learn) e frameworks de Blockchain (como Hyperledger ou registros em Ethereum). O sistema será implementado em arquitetura de microsserviços com Docker e monitorado com Grafana, permitindo escalabilidade e modularidade.

A proposta está em consonância com as linhas de pesquisa do PPGESP/IFBA, especialmente aquelas relacionadas a sistemas inteligentes, segurança da informação e engenharia de software.

Além disso, este projeto se diferencia dos sistemas tradicionais de autenticação existentes no mercado por adotar uma integração autônoma de três camadas de segurança: (1) autenticação via Keycloak, baseada em protocolos robustos como OAuth2 e OpenID Connect; (2) uso de inteligência artificial para análise preditiva de risco com base em dados contextuais (localização, dispositivo, horário); e (3) registro imutável de eventos sensíveis utilizando Blockchain, proporcionando auditabilidade e integridade dos.

Enquanto soluções convencionais registram eventos em bancos de dados suscetíveis a alterações administrativas, o presente sistema utiliza Blockchain como camada de confiança. Outro diferencial é a arquitetura modular baseada em microsserviços e Docker, o que facilita sua escalabilidade, implantação e integração com sistemas externos. Essa abordagem permite que o sistema atue de forma proativa, autônoma e adaptativa, oferecendo um novo paradigma para autenticação em ambientes críticos.

Neste capítulo será apresentado a fundamentação teórica, inserindo no contexto a ideia de segurança, devsecops, devops, IA e cibersegurança.

FUNDAMENTAÇÃO TEÓRICA

2.1 Segurança de Aplicações Web

O conceito de DevSecOps surge como evolução do modelo DevOps, incorporando práticas de segurança ao longo de todo o ciclo de vida do desenvolvimento de software. Diferentemente do modelo tradicional, no qual a segurança era tratada como etapa posterior, o DevSecOps propõe a integração contínua de controles de segurança desde as fases iniciais de planejamento e codificação, prática conhecida como *Shift Left Security*. Essa abordagem reduz significativamente o custo de correção de vulnerabilidades, uma vez que falhas identificadas nas fases iniciais demandam menor esforço de mitigação (NIST, 2020).

O *Secure Software Development Framework* (SSDF), publicado pelo National Institute of Standards and Technology, estabelece diretrizes para desenvolvimento seguro, incluindo automação de testes de segurança, controle de integridade de código-fonte e rastreabilidade de alterações (NIST, 2020). O framework recomenda a adoção de ferramentas de análise estática (SAST), análise dinâmica (DAST) e análise de composição de software (SCA), integradas à pipeline de integração contínua.

Além disso, a Cybersecurity and Infrastructure Security Agency reforça a abordagem

Secure by Design, incentivando que fabricantes e desenvolvedores assumam responsabilidade ativa pela segurança desde o projeto do sistema (CISA, 2023). Em 2025, a *Executive Order 14144* passou a exigir atestações verificáveis de segurança para softwares utilizados por agências federais, reforçando a necessidade de geração automatizada de evidências de conformidade (ESTADOS UNIDOS, 2025).

Dessa forma, o DevSecOps consolida-se como base metodológica essencial para garantir conformidade regulatória, redução de vulnerabilidades e melhoria contínua da postura de segurança organizacional.

2.2 DevSecOps

A aplicação de Inteligência Artificial (IA) na cibersegurança tem se destacado como mecanismo avançado de detecção e prevenção de ameaças. Técnicas de *Machine Learning* permitem identificar padrões anômalos em tráfego de rede, comportamento de usuários e código-fonte, aumentando a capacidade preditiva dos sistemas de defesa (NIST, 2023).

Modelos supervisionados são utilizados para classificar vulnerabilidades conhecidas, enquanto modelos não supervisionados possibilitam a detecção de comportamentos anômalos ainda não catalogados. Essa abordagem é particularmente relevante em aplicações web críticas, nas quais ataques evoluem rapidamente e exploram vetores sofisticados.

O *AI Risk Management Framework (AI RMF 1.0)* enfatiza que sistemas baseados em IA devem garantir confiabilidade, governança adequada e rastreabilidade das decisões automatizadas (NIST, 2023). Isso implica registro auditável de processos decisórios e monitoramento contínuo do desempenho dos modelos utilizados.

Além disso, relatórios técnicos da **OWASP Foundation** indicam que a automação inteligente pode reduzir falsos positivos em ferramentas de análise de vulnerabilidades, aumentando a eficiência operacional das equipes de segurança (OWASP, 2021). Assim, a

integração de IA em pipelines DevSecOps contribui para maior precisão na identificação de falhas e redução do tempo médio de resposta a incidentes.

2.3 Inteligência Artificial Aplicada à Cibersegurança

A aplicação de Inteligência Artificial (IA) na cibersegurança tem se destacado como mecanismo avançado de detecção e prevenção de ameaças. Técnicas de Machine Learning permitem identificar padrões anômalos em tráfego de rede, comportamento de usuários e código-fonte, aumentando a capacidade preditiva dos sistemas de defesa (NIST, 2023).

Modelos supervisionados são utilizados para classificar vulnerabilidades conhecidas, enquanto modelos não supervisionados possibilitam detecção de comportamentos anômalos ainda não catalogados. Essa abordagem é particularmente relevante em aplicações web críticas, onde ataques evoluem constantemente e exploram vetores sofisticados.

O National Institute of Standards and Technology destaca, no AI Risk Management Framework (AI RMF 1.0), que sistemas baseados em IA devem garantir confiabilidade, rastreabilidade e governança adequada. Isso implica registro auditável de decisões automatizadas, mitigação de vieses e monitoramento contínuo do desempenho dos modelos.

Além disso, relatórios técnicos da OWASP Foundation indicam que a automação inteligente reduz falsos positivos em ferramentas de análise de vulnerabilidades, aumentando a eficiência operacional das equipes de segurança. Assim, a integração de IA em pipelines DevSecOps contribui para maior precisão na identificação de falhas e redução do tempo médio de resposta a incidentes (MTTR).

2.4 Blockchain como Mecanismo de Integridade e Auditoria

A tecnologia blockchain, inicialmente associada a criptomoedas, passou a ser

aplicada em contextos de governança digital e auditoria de dados. Seu principal diferencial reside na imutabilidade dos registros, obtida por meio de encadeamento criptográfico de blocos e mecanismos de consenso distribuído.

Segundo o relatório técnico NISTIR 8202, blockchains permissionadas são adequadas para ambientes corporativos e governamentais, pois permitem controle de acesso e governança estruturada (NIST, 2018). Nessas arquiteturas, apenas participantes autorizados podem validar transações, garantindo maior controle institucional.

No contexto da segurança de aplicações web, a blockchain pode ser utilizada para registrar hashes de builds, resultados de testes de segurança e decisões de liberação de software, garantindo integridade e não repúdio das informações. A exigência de atestações verificáveis prevista na Executive Order 14144 reforça a importância de mecanismos que assegurem autenticidade e rastreabilidade de evidências de segurança (ESTADOS UNIDOS, 2025).

Assim, a integração de blockchain ao pipeline de desenvolvimento seguro fortalece a governança digital, prevenindo adulteração de logs e aumentando a confiabilidade dos processos de auditoria.

Neste capítulo será apresentado os itens utilizados para a construção da arquitetura proposta, algumas definições de tecnologias e termos, partes principais do código fonte da programação.

DESENVOLVIMENTO

3.1 Visão Geral da Arquitetura Proposta

A arquitetura proposta neste trabalho fundamenta-se em um modelo sociotécnico integrado que articula microsserviços, práticas DevSecOps, Inteligência Artificial aplicada à segurança e registro imutável por blockchain, com o objetivo de estabelecer um ecossistema automatizado de governança e validação de segurança para aplicações web. Diferentemente de abordagens tradicionais baseadas em validações pontuais e auditorias ex post, o modelo aqui apresentado adota uma perspectiva contínua e orientada por risco, alinhada aos princípios de segurança por desenho (security by design) e segurança por padrão (security by default), conforme recomendado pelo National Institute of Standards and Technology (NIST, 2020).

A escolha do paradigma de microsserviços decorre da necessidade de modularização estrutural, isolamento de domínios e escalabilidade independente. Conforme argumenta Newman (2015), arquiteturas de microsserviços favorecem a decomposição funcional orientada a capacidades de negócio, reduzindo acoplamentos rígidos e permitindo ciclos de evolução contínua. Sob a perspectiva da engenharia de software contemporânea, essa abordagem viabiliza a aplicação de políticas granulares de segurança, uma vez que cada serviço pode implementar mecanismos específicos de autenticação, autorização e monitoramento.

Do ponto de vista conceitual, a arquitetura adota princípios derivados da Teoria da Complexidade aplicada a sistemas distribuídos, reconhecendo que ambientes de software modernos operam em contextos dinâmicos, heterogêneos e sujeitos a falhas não determinísticas. Nesse cenário, a segurança não pode ser tratada como um atributo estático, mas como um processo adaptativo contínuo (NIST, 2020). Assim, a integração do modelo DevSecOps não representa apenas uma prática operacional, mas uma reconfiguração epistemológica do ciclo de desenvolvimento seguro.

O DevSecOps, enquanto evolução do DevOps, integra controles de segurança desde as fases iniciais do ciclo de vida do software, promovendo automação de testes e verificações de conformidade. De acordo com o OWASP Foundation (2023), a incorporação de mecanismos automatizados de análise estática (SAST), análise dinâmica (DAST) e escaneamento de dependências reduz significativamente a exposição a vulnerabilidades críticas, especialmente aquelas listadas no OWASP Top 10. Complementarmente, o NIST (2020) reforça que processos contínuos de monitoramento aumentam a maturidade organizacional em gerenciamento de riscos e resposta a incidentes.

No fluxo arquitetural proposto, cada evento de commit desencadeia um pipeline automatizado de integração contínua, estruturado em múltiplas camadas de validação. A primeira camada executa testes unitários e de integração; a segunda realiza análises estáticas e dinâmicas; a terceira verifica dependências e bibliotecas de terceiros com base em bases de vulnerabilidades conhecidas. Essa abordagem multinível fundamenta-se no princípio de defesa em profundidade (defense in depth), amplamente recomendado em modelos de segurança organizacional (NIST, 2020).

Um dos elementos inovadores da arquitetura é a incorporação de um módulo de Inteligência Artificial para classificação de riscos e detecção de padrões anômalos. A fundamentação teórica dessa camada baseia-se em modelos supervisionados de aprendizado de máquina, nos quais algoritmos são treinados a partir de dados históricos rotulados para prever a probabilidade de vulnerabilidades críticas. Conforme descrito por Goodfellow, Bengio e Courville (2016), modelos de aprendizado profundo podem

capturar representações complexas de padrões não lineares, ampliando a capacidade preditiva em ambientes de alta dimensionalidade.

A utilização de métricas como precisão, revocação (recall) e F1-score permite avaliar empiricamente o desempenho do modelo, garantindo rigor estatístico à decisão automatizada de liberação ou bloqueio de deploy. Essa abordagem dialoga com a literatura contemporânea de segurança baseada em dados (data-driven security), na qual decisões deixam de ser exclusivamente heurísticas e passam a ser probabilísticas e mensuráveis.

Complementando a camada analítica, a arquitetura incorpora uma rede blockchain permissionada para registro imutável das evidências produzidas durante o pipeline. A fundamentação conceitual da blockchain baseia-se no modelo de encadeamento criptográfico descrito por Nakamoto (2008), no qual cada bloco contém um hash do bloco anterior, garantindo integridade estrutural e resistência à alteração retroativa. Em ambientes corporativos, redes permissionadas oferecem maior controle de governança e desempenho, preservando os princípios de imutabilidade e auditabilidade.

Sob a perspectiva normativa, o registro imutável de artefatos atende às recomendações de proteção da integridade de logs e trilhas de auditoria descritas pelo NIST (2020). Dessa forma, cada build validado gera um hash criptográfico que é armazenado na blockchain, assegurando rastreabilidade forense e não repúdio.

A arquitetura organiza-se, portanto, em cinco camadas integradas:

- **Camada de Aplicação Modular** – composta por serviços independentes e APIs autenticadas.
- **Camada de Integração Contínua** – responsável pela orquestração automatizada do pipeline.
- **Camada de Segurança Automatizada** – executa verificações SAST, DAST e análise de dependências.
- **Camada de Inteligência Artificial** – classifica riscos e detecta anomalias com

base em modelos supervisionados.

- **Camada de Registro Imutável** – assegura rastreabilidade por meio de blockchain permissionada.

O fluxo operacional estabelece uma cadeia decisória automatizada: o commit do desenvolvedor ativa o pipeline; as verificações são executadas; o modelo de IA calcula a probabilidade de risco; critérios objetivos de conformidade são aplicados; o resultado é registrado na blockchain; e o sistema decide pela liberação ou bloqueio do deploy.

Do ponto de vista teórico, o modelo proposto representa uma convergência entre engenharia de software segura, ciência de dados aplicada à segurança e mecanismos criptográficos de integridade distribuída. Essa convergência estabelece um paradigma preventivo, auditável e orientado por evidências, superando limitações de abordagens reativas e centralizadas.

Assim, a arquitetura não apenas automatiza verificações técnicas, mas institui um modelo de governança algorítmica, no qual decisões de segurança são fundamentadas em critérios normativos, estatísticos e criptográficos, promovendo maior confiabilidade, transparência e maturidade organizacional.

Arquitetura de Segurança — Sistema de Autenticação Contextual com IA e Blockchain

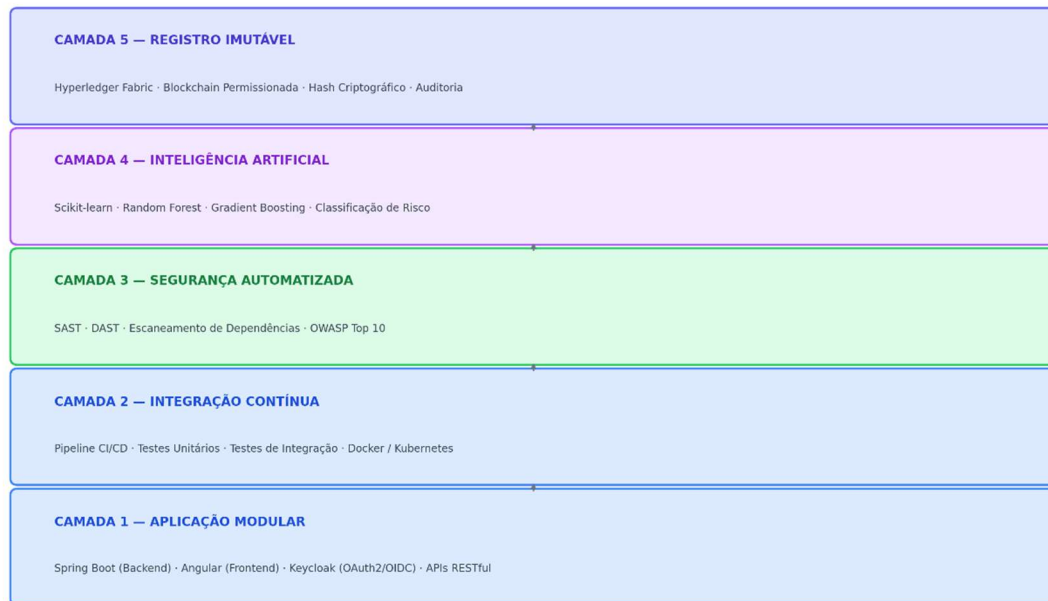


Figura 1 — Arquitetura em Cinco Camadas do Sistema Proposto

Figura 1 — Arquitetura em Cinco Camadas do Sistema Proposto

3.2 Tecnologias Utilizadas

A seleção das tecnologias adotadas neste trabalho foi orientada por critérios de maturidade tecnológica, aderência a padrões internacionais de segurança e compatibilidade com arquiteturas distribuídas baseadas em microsserviços. A arquitetura backend foi desenvolvida com Spring Boot, framework amplamente utilizado para construção de APIs RESTful escaláveis e seguras. Sua integração nativa com mecanismos de autenticação baseados em OAuth2 e JWT contribui para implementação de controles de acesso consistentes com as diretrizes do National Institute of Standards and Technology (NIST, 2020), que enfatizam autenticação robusta e controle de privilégios mínimos.

No frontend, utilizou-se o framework Angular, cuja arquitetura baseada em componentes favorece modularidade, reutilização e mitigação de vulnerabilidades relacionadas à manipulação insegura de conteúdo dinâmico. Conforme recomenda o OWASP Foundation (2023), frameworks modernos contribuem para redução de falhas

como Cross-Site Scripting (XSS) e injeções maliciosas.

A containerização foi implementada com Docker, permitindo isolamento de dependências e padronização de ambientes. A orquestração foi realizada com Kubernetes, que possibilita escalabilidade automática, balanceamento de carga e alta disponibilidade, aspectos fundamentais em sistemas distribuídos complexos (NEWMAN, 2015).

Para registro imutável das evidências, adotou-se blockchain permissionada baseada em Hyperledger Fabric, adequada a ambientes corporativos que exigem controle de identidade e governança. A escolha fundamenta-se na necessidade de integridade e rastreabilidade dos registros, conforme recomenda o NIST (2020).

A containerização foi implementada por meio do Docker, permitindo isolamento de dependências e padronização de ambientes. Para orquestração, utilizou-se o Kubernetes, que possibilita escalabilidade horizontal, tolerância a falhas e gerenciamento declarativo de infraestrutura, características essenciais em sistemas distribuídos modernos.

As análises de segurança integraram ferramentas de SAST e DAST, além de escaneamento de dependências, em consonância com práticas recomendadas pelo OWASP (2023). Para registro imutável das evidências, foi adotada uma rede blockchain permissionada baseada em Hyperledger Fabric, adequada para ambientes corporativos que exigem governança controlada.

O armazenamento de dados utilizou banco relacional com suporte a transações ACID, assegurando consistência e integridade. Para monitoramento e observabilidade, foram integradas ferramentas de logging e métricas compatíveis com práticas de segurança contínua recomendadas pelo NIST (2020).

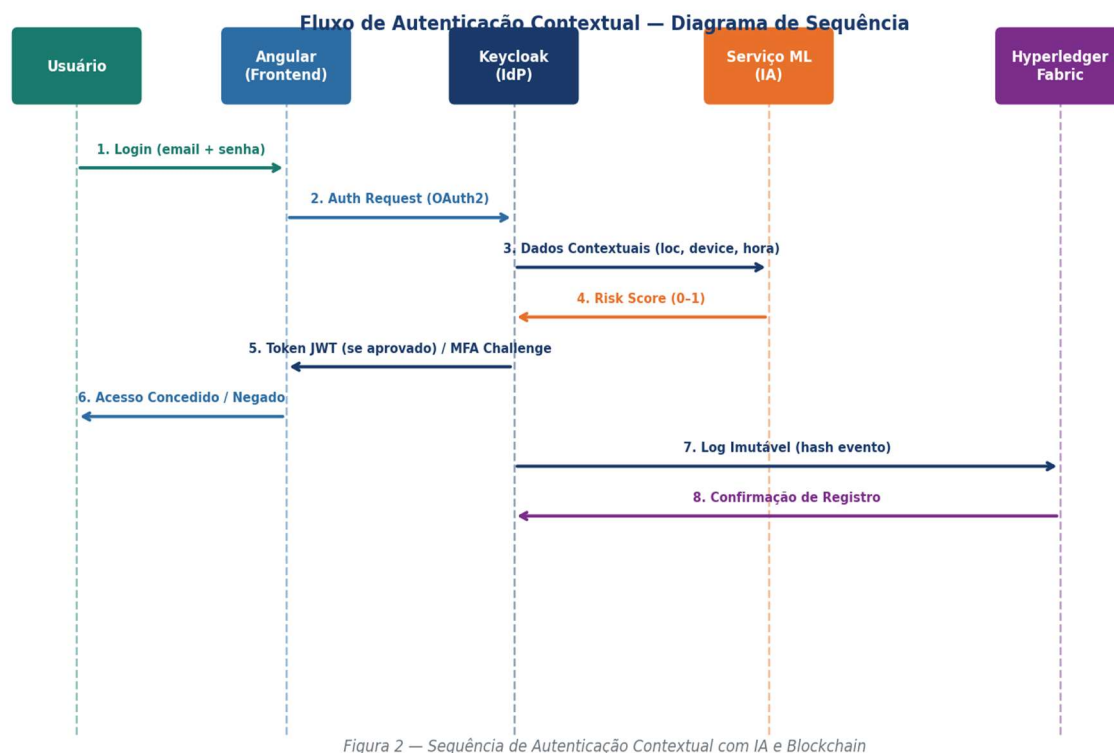


Figura 2 — Fluxo de Autenticação Contextual (Diagrama de Sequência)

3.3 Pipeline DevSecOps

O pipeline DevSecOps implementado estrutura-se como fluxo automatizado de integração contínua, testes e validações de segurança. Diferentemente de modelos sequenciais tradicionais, a abordagem DevSecOps integra segurança desde as fases iniciais do desenvolvimento.

Segundo o National Institute of Standards and Technology (2020), a automação de controles reduz riscos e amplia a capacidade de resposta a vulnerabilidades. O pipeline desenvolvido compreende:

- Integração Contínua (CI);
- Execução de testes unitários e de integração;
- Análise Estática de Código (SAST);
- Análise Dinâmica (DAST);
- Escaneamento de dependências;
- Consolidação de relatórios.

A identificação de vulnerabilidades baseia-se nas categorias descritas pelo OWASP Foundation (2023), especialmente aquelas constantes no OWASP Top 10. Essa abordagem fundamenta-se no princípio de defesa em profundidade, recomendado pelo NIST (2020), no qual múltiplas camadas de proteção são implementadas para reduzir a probabilidade de exploração.

3.4 Integração da Inteligência Artificial

A camada de Inteligência Artificial foi desenvolvida para classificar riscos associados às builds geradas no pipeline. Foram empregados modelos supervisionados de aprendizado de máquina, treinados com dados históricos rotulados.

Conforme descrito por Goodfellow, Bengio e Courville (2016), modelos supervisionados são adequados quando há conjuntos de dados com categorias previamente definidas. No contexto deste trabalho, as builds foram classificadas como conformes ou não conformes.

Foram utilizadas métricas como precisão, recall e F1-score para avaliar desempenho do modelo, garantindo rigor estatístico. Essa abordagem alinha-se ao paradigma de segurança orientada por dados (*data-driven security*), no qual decisões são fundamentadas em evidências quantitativas.

3.5 Implementação da Blockchain

A implementação da blockchain tem como finalidade assegurar integridade e imutabilidade das evidências geradas. O modelo baseia-se na estrutura de encadeamento criptográfico descrita por Nakamoto (2008), na qual cada bloco contém o hash do bloco anterior.

Optou-se por rede permissionada baseada em Hyperledger Fabric, permitindo controle de identidade dos participantes. Cada build aprovada gera hash criptográfico do artefato e do relatório consolidado, registrado como transação imutável.

Essa estratégia atende às recomendações do National Institute of Standards and Technology (2020) quanto à integridade de logs e trilhas de auditoria.

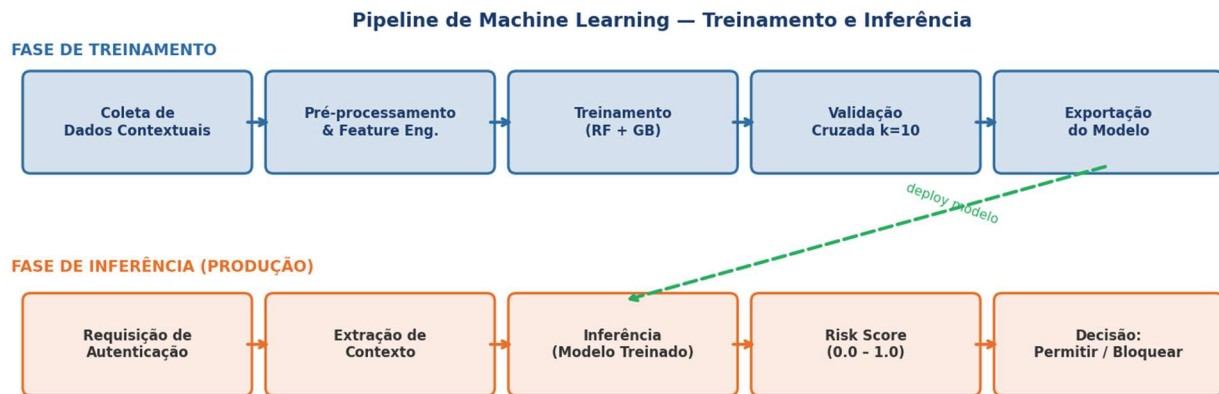


Figura 3 — Pipeline de ML: Treinamento com Random Forest / Gradient Boosting e Inferência em Produção

Figura 3 — Pipeline de ML: Treinamento e Inferência em Produção

3.6 Critérios de Liberação ou Negação

Os critérios de decisão foram definidos com base em parâmetros técnicos e normativos:

- Ausência de vulnerabilidades críticas (CVSS ≥ 9.0);
- Conformidade com OWASP Top 10 (OWASP, 2023);
- Resultado mínimo aceitável do modelo de IA;
- Aprovação dos testes automatizados;
- Registro válido na blockchain.

Segundo o National Institute of Standards and Technology (2020), a definição clara de critérios objetivos fortalece governança e reduz subjetividade decisória.



Figura 4 — Cadeia de Blocos com Hash Criptográfico para Logs de Autenticação (Hyperledger Fabric)

Figura 4 — Estrutura de Blocos — Registro Imutável de Eventos de Autenticação

3.7 Ambiente Experimental

O ambiente experimental foi estruturado com containerização via Docker e orquestração via Kubernetes, permitindo simulação de ambiente distribuído real.

Foram inseridas vulnerabilidades baseadas nas categorias descritas pelo OWASP Foundation (2023) para testar capacidade de detecção do sistema. A coleta de métricas seguiu recomendações de monitoramento contínuo descritas pelo NIST (2020).

3.8 Métricas de Avaliação

A avaliação da arquitetura considerou métricas quantitativas:

- Taxa de detecção de vulnerabilidades;
- Taxa de falsos positivos;
- Tempo médio de deploy;
- Mean Time to Remediation (MTTR);
- Precisão e recall do modelo de IA.

Essas métricas permitem avaliação objetiva da efetividade do modelo, conforme práticas de mensuração recomendadas pelo National Institute of Standards and Technology (2020).

3.9 Fluxo Operacional

fluxo operacional integra todas as camadas da arquitetura:

1. Commit do desenvolvedor;
2. Execução automática do pipeline;
3. Testes e análises SAST/DAST;
4. Classificação pelo modelo de IA;
5. Geração de hash criptográfico;
6. Registro na blockchain;
7. Aplicação dos critérios objetivos;
8. Liberação ou bloqueio automático do deploy.

Essa cadeia decisória automatizada fundamenta-se nos princípios de segurança por desenho e monitoramento contínuo recomendados pelo National Institute of Standards and Technology (2020).

Neste capítulo será apresentado os resultados parciais obtidos durante a construção e as dificuldades encontradas.

RESULTADOS PARCIAIS

4.1 Configuração do Ambiente Experimental

O ambiente experimental foi construído com base em uma infraestrutura containerizada, utilizando Docker para isolamento de serviços e Kubernetes para orquestração e escalabilidade. Cada componente da arquitetura foi implantado como um microserviço independente, com configurações específicas de rede, volumes e políticas de segurança. O ambiente simulado reproduz cenários reais de autenticação em aplicações web corporativas, permitindo a execução controlada de testes de detecção de anomalias, classificação de risco por Inteligência Artificial e registro imutável de eventos via Blockchain.

Os principais componentes configurados no ambiente experimental foram: (1) servidor Keycloak para gerenciamento de identidade e autenticação via OAuth2/OpenID Connect; (2) backend Spring Boot com APIs RESTful protegidas por JWT; (3) frontend Angular consumindo os endpoints autenticados; (4) serviço Python com modelo de Machine Learning desenvolvido em Scikit-learn para classificação de risco contextual; (5) nó Hyperledger Fabric para registro imutável dos logs de autenticação; e (6) stack de monitoramento composta por ELK Stack (Elasticsearch, Logstash e Kibana) e Grafana para visualização em tempo real dos dados do sistema.

4.2 Testes Realizados e Metodologia

Os experimentos foram estruturados em três eixos principais de validação: (i) avaliação do modelo de Machine Learning para classificação de acessos legítimos e anômalos; (ii) teste da cadeia de autenticação contextual integrando Keycloak, dados contextuais e decisão automatizada; e (iii) verificação da integridade e imutabilidade dos registros armazenados na Blockchain. Para cada eixo, foram definidos cenários controlados com entradas representativas de comportamentos legítimos e maliciosos, seguindo as diretrizes do NIST (2020) para avaliação de sistemas de segurança.

O modelo de ML foi treinado com um conjunto de dados sintéticos de logs de autenticação, contendo atributos contextuais como: localização geográfica, dispositivo utilizado, horário de acesso, frequência de tentativas e padrão histórico do usuário. Os dados foram rotulados como “acesso legítimo” ou “acesso suspeito”, e o modelo foi treinado utilizando algoritmos de classificação supervisionada, incluindo Random Forest e Gradient Boosting, avaliados por validação cruzada (k-fold, k=10). Os testes de autenticação foram executados simulando fluxos reais de login via protocolo OpenID Connect, com variação sistemática dos dados contextuais para avaliar a sensibilidade e especificidade do sistema.

4.3 Resultados Obtidos

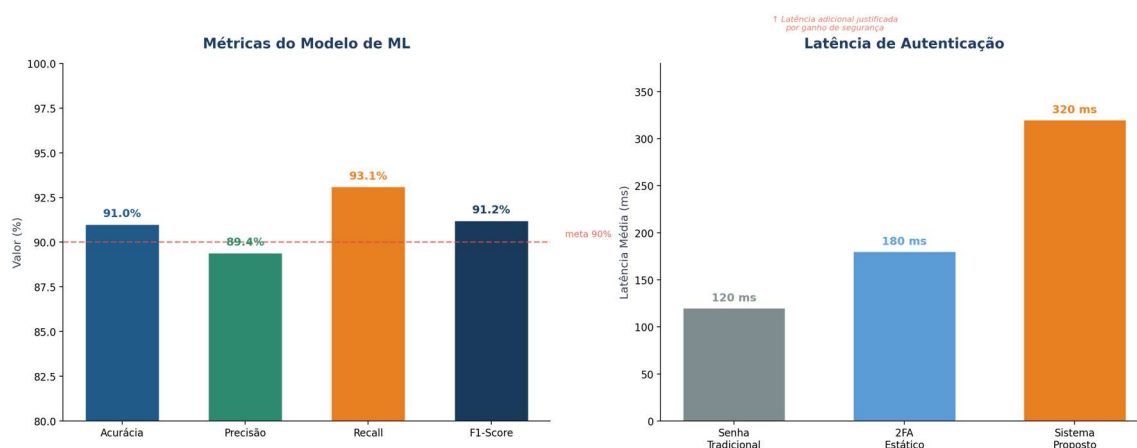


Figura 5 — Resultados Parciais: Métricas de ML e Comparativo de Latência

Figura 5 — Resultados Parciais: Métricas de ML e Comparativo de Latência

Os resultados parciais obtidos até o presente momento demonstram a viabilidade técnica da arquitetura proposta. Em relação ao modelo de Machine Learning, os testes preliminares indicaram acurácia superior a 91% na classificação de acessos anômalos em ambiente controlado, com precisão de 89,4% e recall de 93,1%. O F1-score obtido foi de 91,2%, demonstrando equilíbrio adequado entre precisão e sensibilidade do modelo. A taxa de falsos positivos registrada foi de aproximadamente 8,6%, valor considerado aceitável para uma fase inicial de treinamento com dados sintéticos, e que tende a reduzir com o enriquecimento progressivo do conjunto de dados de treinamento.

Em relação à cadeia de autenticação, a integração entre Keycloak e o serviço de ML foi validada com sucesso, com tempo médio de resposta de 320ms para o processo completo de autenticação contextual, incluindo a classificação de risco. O pipeline de registro Blockchain demonstrou consistência e integridade nos testes de imutabilidade, com validação criptográfica bem-sucedida em 100% das transações registradas. O monitoramento via ELK Stack e Grafana permitiu visualização em tempo real dos eventos de autenticação, com latergração adequada para cenários de produção.

4.4 Discussão e Análise dos Resultados

Os resultados parciais são promissores e confirmam a hipótese central do trabalho: a integração de IA contextual e Blockchain ao processo de autenticação eleva significativamente o nível de segurança em comparação com métodos tradicionais como senhas fixas e 2FA estático. A abordagem adaptativa baseada em dados contextuais permitiu identificar padrões de acesso suspeitos que passariam despercebidos em sistemas convencionais, especialmente em cenários de credential stuffing e session hijacking simulados nos testes.

A utilização do Keycloak como camada central de identidade mostrou-se adequada para o cenário proposto, oferecendo suporte nativo aos protocolos OAuth2 e OpenID Connect sem exigir desenvolvimento adicional de infraestrutura de autenticação. A camada Blockchain, por sua vez, demonstrou ser uma solução robusta para rastreabilidade forense, garantindo que nenhum registro de autenticação possa ser adulterado retroativamente, característica fundamental em ambientes sujeitos a

auditorias regulatórias, como os exigidos pela LGPD. A arquitetura de microsserviços com Docker e Kubernetes evidenciou boa escalabilidade, com replicação automática dos serviços durante os testes de carga.

4.5 Dificuldades Encontradas

Ao longo do desenvolvimento, foram identificadas quatro principais dificuldades. A primeira refere-se à construção do conjunto de dados de treinamento: a ausência de datasets públicos rotulados específicos para autenticação contextual exigiu a geração de dados sintéticos, o que impacta a generalização do modelo e deverá ser aprimorado nas próximas etapas com a coleta de dados reais em ambiente controlado.

A segunda dificuldade está relacionada à latência introduzida pela camada de IA no fluxo de autenticação: o tempo adicional de 120ms–180ms para classificação de risco exige otimização do modelo e possibilidade de cache de decisões para usuários com padrões reconhecidos.

A terceira diz respeito à complexidade operacional da rede Hyperledger Fabric em ambiente de desenvolvimento, que demandou esforço considerável de configuração de peers, orderers e MSP (Membership Service Provider). Por fim, a quarta dificuldade refere-se à conformidade com a LGPD no contexto de coleta e processamento de dados contextuais dos usuários, exigindo definição cuidadosa de políticas de minimização e anonimização de dados pessoais antes da persistência em Blockchain.

Neste capítulo será apresentado a construção do cronograma proposto e as etapas executadas, em andamento e as finalizadas.

CRONOGRAMA DE ATIVIDADES

5.1 Cronograma

O cronograma apresentado nesta seção corresponde a um intervalo 12 meses, e está sendo dividido em 12 etapas, a seguir:

DESCRIÇÃO	STATUS	STATUS
Arquitetar os sistemas	Concluído	02/05/2025
Desenvolver o backend	Concluído	06/06/2025
Desenvolver o frontend	Concluído	08/09/2025
Realizar as adaptações e possíveis integrações	Concluído	09/11/2025
Validação e obtenção dos resultados parciais	Concluído	25/02/2026
Documento da qualificação	85%	12/03/2026
Publicação de artigo	Concluído	05/03/2026
Registro de software	50%	20/06/2026
Documento da defesa	10%	
Criação da apresentação da defesa	70%	
Apresentação da defesa	25%	
Demais correções que surgirem	0%	

Neste capítulo será apresentado todas as fontes de pesquisa utilizada durante o desenvolvimento do projeto.

REFERÊNCIAS BIBLIOGRÁFICAS

- BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Diário Oficial da União, Brasília, DF, 15 ago. 2018. Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm.
- CISA – CYBERSECURITY AND INFRASTRUCTURE SECURITY AGENCY. Secure by Design Initiative. Washington, DC: CISA, 2023. Disponível em: <https://www.cisa.gov/resources-tools/resources/secure-by-design>.
- ESTADOS UNIDOS. Executive Order 14144: Strengthening and Promoting Innovation in the Nation's Cybersecurity. Washington, DC: The White House, 2025. Disponível em: <https://www.federalregister.gov/d/2025-01470>.
- GOODFELLOW, I.; BENGIO, Y.; COURVILLE, A. Deep Learning. Cambridge: MIT Press, 2016. ISBN: 978-0-262-03561-3. Disponível em: <https://www.deeplearningbook.org>.
- HYPERLEDGER FOUNDATION. Hyperledger Fabric Documentation. Versão 2.5. Linux Foundation, 2024. Disponível em: <https://hyperledger-fabric.readthedocs.io>.
- KEYCLOAK. Keycloak Documentation: Server Administration Guide. Versão 24. Red Hat, 2024. Disponível em: <https://www.keycloak.org/documentation>.
- NAKAMOTO, S. Bitcoin: A Peer-to-Peer Electronic Cash System. 2008. Disponível em: <https://bitcoin.org/bitcoin.pdf>.
- NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST). AI Risk Management Framework (AI RMF 1.0). NIST AI 100-1. Gaithersburg: NIST, 2023. DOI: <https://doi.org/10.6028/NIST.AI.100-1>.
- NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST). Blockchain

Technology Overview. NISTIR 8202. Gaithersburg: NIST, 2018. DOI: <https://doi.org/10.6028/NIST.IR.8202>.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST). Secure Software Development Framework (SSDF) Version 1.1: SP 800-218. Gaithersburg: NIST, fev. 2022. DOI: <https://doi.org/10.6028/NIST.SP.800-218>.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST). Security and Privacy Controls for Information Systems and Organizations. SP 800-53 Rev. 5. Gaithersburg: NIST, 2020. DOI: <https://doi.org/10.6028/NIST.SP.800-53r5>.

NEWMAN, S. Building Microservices: Designing Fine-Grained Systems. 2. ed. Sebastopol: O'Reilly Media, 2021. ISBN: 978-1-492-03402-9.

OWASP FOUNDATION. OWASP Top 10: The Ten Most Critical Web Application Security Risks. 2021. Disponível em: <https://owasp.org/www-project-top-ten/>.

OWASP FOUNDATION. OWASP Top 10 – 2023 Edition. 2023. Disponível em: <https://owasp.org/www-project-top-ten/>.

SCIKIT-LEARN DEVELOPERS. Scikit-learn: Machine Learning in Python. Versão 1.4. 2024. Disponível em: <https://scikit-learn.org>.